# CYBERCORP SECURITY

DASHBOARD DE SEGURIDAD | Reporte Global de Riesgo Humano

| DEPARTAMENTOS | PERIODO | ESTADO | REPORTE ID |
|---|---|---|---|
| IT, Marketing | 1/3/2026 - 1/3/2026 | Consolidado | GEN-901997 |

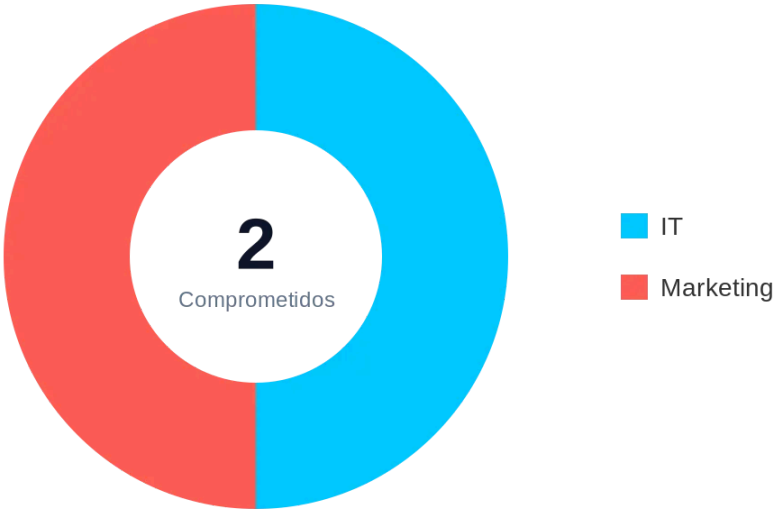
**2**
USUARIOS AUDITADOS

**100%**
TASA APERTURA

**100%**
TASA PHISHING

**2**
COMPROMETIDOS

## USUARIOS COMPROMETIDOS POR DEPARTAMENTO




## ANÁLISIS EJECUTIVO DE RIESGOS

Resumen ejecutivo crítico: se enviaron 2 correos de prueba y ambos destinatarios abrieron y clicaron en el enlace (tasa de apertura y de clics del 100%), resultando en 2 usuarios comprometidos. Estos indicadores muestran una vulnerabilidad operativa y técnica grave: el vector de phishing fue completamente eficaz contra la población objetivo, y las barreras de mitigación (formación, controles técnicos y detección) no funcionaron. Riesgos inmediatos: compromiso de cuentas con posible exfiltración de credenciales, acceso no autorizado a sistemas internos, movimiento lateral y pérdida de confidencialidad, integridad o disponibilidad de activos críticos. Causas probables: campañas de

concienciación insuficientes o mal diseñadas, ausencia o baja adopción de autenticación multifactor y de políticas de acceso condicional, filtrado de correo saliente/entrante ineficaz (falta de sandboxing de enlaces, ausencia de URL rewriting y análisis dinámico), configuraciones incompletas de SPF/DKIM/DMARC o bypass de proveedores, y/o carencias en EDR/EDR alerting y en la respuesta del SOC. Control de detección insuficiente: no hay señales preventivas ni alertas que hayan bloqueado el intento, lo que sugiere brechas en logging, correlación (SIEM) y playbooks de respuesta. Impacto organizacional: aun con un número pequeño de usuarios, la tasa de éxito del ejercicio revela riesgo sistémico que podría escalar con un ataque real. Recomendación general: ejecutar contención inmediata y forense, seguir con restauración y remediación técnica, y desplegar un plan de fortalecimiento integral (personas, procesos y tecnología) con métricas y gobernanza claras.

## PLAN DE ACCIÓN Y MITIGACIÓN

- **Contención inmediata (0–48 horas):** restablecer credenciales de los 2 usuarios comprometidos, revocar tokens/sesiones activas, forzar MFA y bloquear cuentas comprometidas hasta la investigación; responsable: SOC/Helpdesk; prioridad: crítica.
- **Investigación forense (24–72 horas):** ejecutar análisis de EDR en los endpoints afectados, recoger logs de correo, proxy, VPN y SIEM, identificar alcance del compromiso (archivos accedidos, movimientos laterales, exfiltración); responsable: Equipo de IR y forense; prioridad: crítica.
- **Mitigación técnica inmediata:** aplicar bloqueo de URL indicadores de compromiso, actualizar reglas de gateway de correo, habilitar sandboxing de enlaces, activar o endurecer URL rewriting y ATP; responsable: Equipo de Email Security; plazo: 48–72 horas.
- **Autenticación y acceso:** desplegar MFA obligatorio para accesos privilegiados y usuarios en riesgo, aplicar políticas de acceso condicional (geo/ip/risk), y rotación forzada de contraseñas tras la contención; responsable: IAM/IT; plazo: 7 días.
- **Mejoras de detección y monitoreo (7–30 días):** integrar y calibrar reglas en SIEM para detección de phishing exitoso (clics, inicios de sesión anómalos), activar alertas de riesgo por comportamiento y ejecutar threat hunting para TTPs observados; responsable: SOC; plazo: 14–30 días.
- **Endurecimiento de correo electrónico (7–30 días):** verificar y aplicar políticas SPF/DKIM/DMARC con modo de monitoreo y posterior bloqueo, desplegar filtros avanzados (ML anti-phishing), y revisar configuración de proveedores de email; responsable: Infraestructura/Seguridad de Email; plazo: 14 días.
- **EDR y protección de endpoints (14–60 días):** asegurar cobertura completa de EDR, actualizar firmas/IOCs, establecer respuesta automatizada (aislamiento) y pruebas de efectividad; responsable: Endpoint Team; plazo: 30 días.
- **Formación y simulación (corto/medio plazo):** diseñar y ejecutar programa de concienciación con simulaciones periódicas de phishing dirigidas, feedback personalizado y métricas (objetivo: reducir tasa de clics por debajo del 15% en 6 meses); responsable: CISO/HR; plazo: iniciar en 7–30 días, programar campañas trimestrales.
- **Políticas y gobernanza (30–90 días):** revisar y actualizar políticas de seguridad, controles de privilegios mínimos, y el plan de respuesta a incidentes; establecer SLA, responsables y reporte a la dirección; responsable: CISO/Gobernanza; plazo: 30–90 días.
- **Pruebas y ejercicios (30–90 días):** realizar tabletop y ejercicios de incidente enfocados en phishing y compromiso de credenciales; evaluar tiempos de detección y respuesta; responsable: CISO/IR; plazo: dentro de 60–90 días.
- **Medidas preventivas avanzadas (90–180 días):** considerar implementaciones de aislamiento de navegador, protección de navegación web, autenticación sin contraseña donde sea viable y

segmentación de red para limitar movimiento lateral; responsable: Arquitectura de Seguridad; plazo: 3–6 meses.

- **Métricas y seguimiento:** establecer KPIs claros: tasa de apertura y clics en simulaciones, porcentaje de usuarios comprometidos, tiempo medio de detección (MTTD) y tiempo medio de respuesta (MTTR). Reportar al comité de dirección mensual hasta mitigación completa; responsable: CISO/Security Ops.
- **Comunicación y cumplimiento:** preparar comunicación interna y, si aplica, notificaciones regulatorias por exposición de datos; coordinar con legal/privacidad; responsable: CISO/Legal/Privacidad; plazo: inmediata según resultados forenses.

## DETALLE DE ACTIVIDAD (ÚLTIMOS EVENTOS)

| USUARIO / EMAIL | DPTO. | ABIERTO | CLICADO | COMPROMETIDO | NIVEL RIESGO |
|---|---|---|---|---|---|
| esauccifer2@gmail.com | IT | Sí | Sí | SÍ | Crítico |
| esauccifer2@gmail.com | Marketing | Sí | Sí | SÍ | Crítico |

Documento confidencial. Generado el 1/3/2026. © CyberCorp Security.